Preventing Security Misconfiguration

- **Secure by default:** Apply hardening guidelines across the entire stack
- **Minimize attack surface:** Disable unnecessary features, services, and accounts
- **Automate configuration:** Use consistent, repeatable configurations across environments
- **Keep configurations updated:** Review security settings after patches and upgrades
- **Enforce isolation:** Segment components and restrict cloud permissions
- **Secure credentials:** Avoid hardcoded secrets; use short-lived credentials
- **Validate security:** Automate configuration checks, restrict error details, and enforce security headers

A03 - Software Supply Chain Failures

- **Problem:** Vulnerabilities or compromises in third-party components, development tools, or software build and distribution processes
- **Impact:** Malicious code injection, application compromise, or widespread supply chain attacks

Common vulnerabilities:

- **Vulnerable dependencies:** Outdated, unpatched, or unsupported libraries and frameworks
- **Untrusted components:** Malicious or compromised third-party packages
- **Dependency blind spots:** Untracked direct or transitive dependencies
- **Insecure CI/CD:** Compromised build pipelines, repositories, or developer tools
- **Weak access controls:** Excessive privileges and lack of separation of duties
- **Poor change management:** Untracked changes to code, tools, or dependencies